

מודול 5 — איסוף מידע — תרגול

חומר לימוד

1 יחידות

תוכן העניינים

1. 🧠 תרגול — מודול 5: איסוף מידע (Reconnaissance)

תרגול — מודול 5: איסוף מידע (Reconnaissance)

חלק א' — שאלות תרגול (עם תשובות). חלק ב' — תרחיש מהחיים האמיתיים.

חלק א' — שאלות תרגול

- Q1.** מה ההבדל בין איסוף פסיבי לאקטיבי? תן דוגמה לכל אחד.
- Q2.** מהו Scope, ומה ההבדל בין In-Scope ל-Out-of-Scope?
- Q3.** איזה כלי מזהה את תבנית המייל של ארגון?
- Q4.** למה תת-דומיין בשם `dev` מעניין תוקף במיוחד?
- Q5.** כתוב Google Dork שמוצא עמודי התחברות בדומיין `target.com`.
- Q6.** מהו דלף מידע (Data Breach), ואיך הוא מנוצל בבדיקה?
- Q7.** Burp Suite — כלי מאיזה סוג, ועל איזה פורט הוא מאזין כברירת מחדל?
- Q8.** איזה כלי משמש לגילוי תת-דומיינים, ומה הדגל לציון הדומיין?

תשובות 

1. פסיבי=ללא מגע (Google, LinkedIn); אקטיבי=מגע ישיר (nmap, Sublist3r).
2. Scope=גבולות ההרשאה; In-Scope מותר לתקוף, Out-of-Scope אסור במפורש.
3. **hunter.io** (וגם clearbit, phonebook.cz).
4. סביבות פיתוח מאובטחות פחות (סיסמאות ברירת מחדל, דיבוג פתוח, גרסאות ישנות).
5. `site:target.com inurl:login`.
6. דלף פרטי גישה מפריצות עבר; מנוצל לכניסה ישירה / Password Spraying (בתוך Scope).
7. **Proxy** בין דפדפן לשרת; מאזין על `127.0.0.1:8080`.
8. **Sublist3r**; `sublist3r -d target.com`.

חלק ב' — תרחיש מהחיים האמיתיים

“תיק מודיעין על יעד” 

קיבלת בדיקה External עם Scope: *.target.com. **בצע OSINT פסיבי בלבד** (על דומיין ציבורי לתרגול, או יעד Bug Bounty בתוך Scope) והרכב תיק מודיעין:

```
# 1. תת-דומינים
sublist3r -d TARGET.com
# 2. טכנולוגיות (בדפדפן: builtwith.com / Wappalyzer)
whatweb https://TARGET.com
# 3. זהה תבנית – (בדפדפן hunter.io) מיילים
# 4. Google Dorking:
#   site:TARGET.com filetype:pdf
#   site:TARGET.com inurl:admin
```

המשימה: הרכב מסמך עם: (א) 3 תת-דומינים, מהם החשודים כפגיעים; (ב) ה-Tech Stack; (ג) תבנית המייל; (ד) ממצא Dorking מעניין אחד; (ה) פסקת מסקנה — מהו משטח התקיפה הבולט והצעד הבא.

 **פסיבי בלבד** — אין לשלוח מיילים, לנסות התחברות, או לסרוק אקטיבית נכס שאינו במעבדה/Scope שלך.

פתרון מנחה

תיק טוב יזהה: תת-דומינים כמו dev/staging/vpn (מסומנים כחשודים), Tech Stack (שרת+גרסה+CMS), תבנית מייל ({first}.{last}@), וממצא Dorking (מסמך/פאנל חשוף). מסקנה לדוגמה: “משטח התקיפה הבולט הוא dev.target.com (סביבת פיתוח חשופה). הצעד הבא: סריקת nmap ממוקדת אליו (מודול 6).”

 זהו הקלט לשלב הסריקה. Recon טוב = חצי מהעבודה.

 חזרה למודול · תרגילים מעשיים